

Security+ 4.3 · Vulnerability Scanning

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.3 — Vulnerability Scanning**
(7:45) · [Vídeo no YouTube ↗](#)

Resumo da Aula: Scanner: vulnerability scan (procura CVE conhecido — Nessus, Qualys, OpenVAS); SAST (static — lê o código); fuzzing (input maluco até quebrar). Vulnerability feed alimenta o scanner.

Highlights que a prova cobra

- Vuln scan: compara o sistema com o CVE conhecido
- Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra

Dicas de prova & Cenários Típicos

- 'automated tool checks for known vulnerabilities'=vulnerability scan

Cenário clássico de exame: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE.

 **Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e**

Armadilhas da Seção 4.3)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Vulnerability Scanning) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Monitoramento de Segurança (SIEM, SOAR, EDR/XDR):**
 - **SIEM:** centraliza, normaliza e correlaciona eventos de logs em tempo real para disparar alertas de segurança.
 - **SOAR:** automatiza respostas a incidentes através de playbooks coordenados, reduzindo o tempo de reação humano.
 - **EDR/XDR:** detecção e resposta a anomalias no endpoint (EDR) estendida a e-mail, nuvem e identidades (XDR).
- **Fases da Resposta a Incidentes (NIST SP 800-61 / PICERL):**
 1. **Preparação:** políticas, ferramentas, treinamentos.
 2. **Identificação/Detecção:** triagem de alertas e confirmação do incidente.
 3. **Contenção:** isolamento do sistema afetado para impedir propagação (sem destruir provas).
 4. **Erradicação:** remoção de malwares, fechamento de brechas e contas comprometidas.
 5. **Recuperação:** restauração segura dos serviços a partir de backups limpos e validação de produção.
 6. **Lições Aprendidas:** reunião pós-incidente e melhorias nos playbooks.
- **Forense Digital e Ordem de Volatilidade (RFC 3227):** Durante a coleta de evidências forenses, os artefatos mais voláteis (que somem ao desligar) devem ser capturados primeiro:
 1. Registradores da CPU e memória Cache.
 2. Memória RAM (volátil: contém senhas em claro, chaves criptográficas em uso e conexões ativas).
 3. Estado das conexões de rede e processos em execução.
 4. Sistema de arquivos e discos rígidos (HD/SSD).
 5. Mídias ópticas e backups externos arquivados.

⚠ **Armadilhas e Pegadinhas Clássicas da Banca:**

- NUNCA desligue ou reinicie um servidor comprometido antes de realizar o dump forense da memória RAM; reiniciar destrói evidências essenciais de malwares fileless.
- Qualquer manipulação de evidência digital exige cálculo imediato de hash (SHA-256) e registro rigoroso da Cadeia de Custódia (Chain of Custody).

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. No sistema CVSS 3.1, uma vulnerabilidade com pontuação 9.8 é classificada como:

- A)** Baixa
- B)** Média
- C)** Alta
- D)** Crítica

2. Uma vulnerabilidade CVE-2024-1234 pontuou CVSS 3.1 como 7.5 (Alta). O que deve ser feito PRIMEIRO?

- A)** Aplicar patch imediatamente em todos os servidores
- B)** Avaliar o risco no contexto do ambiente específico
- C)** Ignorar pois não é crítica
- D)** Substituir o sistema afetado

3. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Vuln scan: compara o sistema com o CVE conhecido'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Vuln scan: compara o sistema com o CVE conhecido...

4. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'automated tool checks for known vulnerabilities'=vulnerability scan'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'automated tool checks for known vulnerabilities'=vulnerability scan...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando C...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Vuln scan: compara o sistema com o CVE conhecido'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Vuln scan: compara o sistema com o CVE conhecido...

8. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'automated tool checks for known vulnerabilities'=vulnerability scan'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'automated tool checks for known vulnerabilities'=vulnerability scan...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Vulnerability Scanning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando C...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) D — Crítica.

✓ **Por que está certa:** CVSS classifica: Baixa (0.1-3.9), Média (4.0-6.9), Alta (7.0-8.9), Crítica (9.0-10.0). Uma pontuação de 9.8 é considerada Crítica.

✗ **Por que as outras estão erradas:**

- *Baixa:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Média:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Alta:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) B — Avaliar o risco no contexto do ambiente específico.

✓ **Por que está certa:** CVSS fornece severidade técnica, mas o risco real depende de fatores contextuais: exposição do sistema, dados armazenados, controles compensatórios. Deve-se avaliar primeiro.

✗ **Por que as outras estão erradas:**

- *Aplicar patch imediatamente em todos os servidores:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Ignorar pois não é crítica:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Substituir o sistema afetado:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) D — Implementar a solução correspondente: Vuln scan: compara o sistema com o CVE conhecido....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): Vuln scan: compara o sistema com o CVE conhecido.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) C — Implementar a solução correspondente: Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola

frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) A — Implementar a solução correspondente: 'automated tool checks for known vulnerabilities'=vulnerability scan....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): 'automated tool checks for known vulnerabilities'=vulnerability scan.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando C....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: Vuln scan: compara o sistema com o CVE conhecido....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): Vuln scan: compara o sistema com o CVE conhecido.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para

detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: 'automated tool checks for known vulnerabilities'=vulnerability scan....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): 'automated tool checks for known vulnerabilities'=vulnerability scan.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) A — Implementar a solução correspondente: 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Vulnerability Scanning): 'scanner informa que o servidor tem CVE-2023-12345'=vuln scan encontrando CVE..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para

detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.